

ISSEM Final Project (Individual assignment)

The final project is an individual written assignment for which you are required to submit a report in pdf on Brightspace. This assignment is to be submitted in Brightspace, NOT peerceptiv, and will be graded by the professor. You are allowed to refer to anything but you cannot collaborate with anyone else in the class. Ultimately the submission content should be yours and yours alone.

This assignment is in two parts. You should make one single submission answering both parts.

Part I — LLM-Assisted Vulnerability Discovery (Individual)

Objective. In Labs 3 and 4 your group identified and patched a set of vulnerabilities in the Infant Incubator Simulator. In this question you will go further: using an LLM as an analysis assistant, find **additional** vulnerabilities in the codebase that were not already covered in your group's Lab 3/4 submissions, validate them manually against the actual running code, and document them in a report that will feed Section 6 (Software Analysis) of your final project.

Scope: Work against the simulator at <https://github.com/rajan0112/Infant-Incubator-Simulator> , specifically `infinc.py` , `SampleNetworkServer.py` , `SampleNetworkClient.py` , and `SampleClient.py` . You may run the code locally to test your findings.

Using an LLM is encouraged. You may use any LLM (ChatGPT, Claude, Gemini, etc.) and any static-analysis tool (e.g., Bandit, Semgrep) to help you locate candidate vulnerabilities. However, you may not collaborate with another person including your group members, and the analysis, validation, and writing must be your own. To receive full credit you must:

1. Validate every vulnerability you report. A finding is only accepted if you confirm it is real and reachable in this code by tracing the exact lines responsible and analyse the vulnerability. Unverified findings copied from an LLM will not be counted.
2. Report at least one false positives. LLMs over-report. List at least two vulnerabilities the LLM (or tool) suggested that turned out to be non-existent, non-reachable, or non-exploitable in this codebase, and explain in one or two sentences why each is a false positive. This triage is part of the grade.
3. Include a prompt appendix. Attach the prompts you used and the relevant LLM/tool output, so the discovery process is transparent (Preferably a screenshot of the prompt).
4. Find new ground. The vulnerabilities you report here must be distinct from those already submitted in your group's Lab 3/4. Briefly note which Lab 3/4 findings you are excluding so there's no overlap.

Extra Credit:

demonstrating a short proof-of-concept script, a packet capture, an execution trace, or a before/after screenshot.

What to submit. Identify at validated vulnerabilities and present them in the table below (same column structure as Section 6 of the final project, with a few additions for this exercise):

Vuln	Affected component / file & line(s)	Description	CWE	Severity (with 1-line justification)	How discovered (LLM / tool / manual)	How validated (PoC / trace / screenshot)	Affected Requirement #	Recommended fix

For each confirmed vulnerability, also write a short paragraph (3–5 sentences) in your own words explaining the root cause and the realistic impact in the context of a networked medical device — e.g., what an attacker on the same network could do. Map each one to a security requirement from your requirements table where possible.

Reminder: This is an individual submission. You may reference any material and use LLMs as described above, but the content must be yours alone.

Demo link: https://drive.google.com/file/d/1mGYsQtZijLPlcnZR5DHEZzI3-SBvXN_4/view?usp=share_link

Part II.

The objective of this assignment for you to imagine that you are submitting your final security analysis report on the Incubator product to product management. Your report should start with the motivation for the analysis and end with your conclusion/recommendation.

Applying the lessons of our course to our simulated Medical Device Infant Incubator

You have been working in the Written Assignment and Labs on the simulated Infant Incubator. In this assignment you will apply the entire security review process that we have covered in the lectures to this product. Specifically you will have the following sections. Most of these will be simply copies of your written assignments and labs:

0. Background

Explain the product in brief and why security is important here.

1. Security Requirements for the Infant Incubator

Requirement #	Requirement Component applies to (either component or overall system)	Requirement Description	Is this requirement met in the final product	
1.				

2. DFD for the Infant Incubator

3. Asset List

Asset #	Asset Name	Asset Description	Concrete or Abstract Asset?	Critical Asset or no?
1.				

4. Threat List

Threat #	Affected Component(s)	Threat Category (if applicable)	Threat Severity (if available)	Recommended Control
1.				

5. Risk Analysis

Take at least 3 threats from Threat List and analyze the Risk level (provide justification)

Risk #	Risk Name	Related Threat (if applicable)	Likelihood	Impact	Risk Level
1.					

6. Software Analysis

Take the results of your Lab 5 and 6 submissions and include those (or more) vulnerabilities in the following table. No need to do further software analysis or coding.

Vulnerability #	Affected Component	Description	Affected Requirement # (if known)	Recommended Fix
1.				

You can use the materials used in the lectures to construct each one of these deliverables. You may (and are encouraged to) use the work you have done in the Labs on securing the product code.

7. Final Conclusion on Release

Based on your consolidated analysis, answer the following question:

In your opinion, is this product ready. Specifically do you recommend to

- (i) Launch as is, with recommended fixes to be pushed as patches in the field in the near future, or**
- (ii) Launch only after the recommended fixes are implemented and validated, or**
- (iii) Do a serious redesign and redevelopment and do this review again.**

Argue your case in text based on the data in the previous sections. At least 1000 words.

Notes:

1. This is a report that will be read by a variety of people (only some of whom have a stake in the product) in the organization, many of whom will be non-security experts or in leadership. So keep technical terminology to a minimum but use it where necessary
2. Your report must be intelligible to all readers but more importantly, you must sell your conclusion to the readers with your justifications. Hence the need for text.
3. Some of your readers will be hostile to security in general, and so your conclusions especially negative ones must be well-defended and a hostile reader should not be able to easily poke holes in your logic (but not necessarily perfect – a reader can always find flaws – superficial flaws are ok, but not logical/inferential)
4. Remember that this document will go on record, so any future disasters will be tracked back to this document. So remember to analyze your risk and not over or underestimate it. Document your caveats and assumptions.
5. You can structure your Conclusions to your taste keeping the above in mind. Remember that if you don't convince the audience of your recommendation, it may become possible that the organization makes the wrong decision security-wise. Furthermore, even more dangerously, you will likely not be invited to review future product decisions for security if the report is deemed unsatisfactory.